

IAM Audit Log Analysis for Service Account Auto-Creation Events

Category: Reference

Model: IAM-LOGS-003

Description: This document explains how to analyze IAM audit logs to detect auto-created service accounts and scope elevation events, with examples from the incident, including scope IDs like **SCOPE-PROD-API-ADMIN**. It details typical log entries, timestamps, and associated user actions.

Table of Contents

- [1. Introduction](#)
- [2. Background and Use Cases](#)
- [3. Log Entry Structure and Common Signatures](#)
- [4. Detecting Service Account Auto-Creation Events](#)
- [5. Scope Elevation and Privilege Escalation Detection](#)
- [6. Incident Examples and Analytical Scenarios](#)
- [7. Known Signatures and False Positives](#)
- [8. Response Strategies and Mitigation](#)
- [9. Appendices and Additional Resources](#)

1. Introduction

This document provides a comprehensive framework for analyzing Identity and Access Management (IAM) audit logs, with a focus on identifying automated service account creation events and privilege escalation activities within cloud environments. Understanding these

events is critical for threat-hunting, incident response, and maintaining operational security. The procedures outlined leverage specific log signatures, incident scenarios, and detection indicators gathered over the past six months, integrating EDR artifacts, network indicators, and IAM-specific notes.

2. Background and Use Cases

2.1 Purpose and Scope

The primary goal is to facilitate proactive detection and rapid investigation of anomalous IAM activities, particularly around service account auto-creation and privilege elevation that could signal lateral movement, privilege escalation, or automated attack chains.

2.2 Threat-Hunting and Incident Response Scenarios

- **Detection of Auto-Created Service Accounts:** Identifying unknown or unexpected service accounts created without authorized approval.
- **Privilege Escalation Monitoring:** Monitoring scope IDs like `SCOPE-PROD-API-ADMIN` for suspicious activity.
- **Malicious Automation Campaigns:** Detecting patterns matching known malicious signatures such as *BEACON-12xx*, C2-DNS patterns like *C2-DNS-30xx*.

2.3 Integration with Threat Intelligence and Security Tools

Correlates IAM logs with Endpoint Detection and Response (EDR) artifacts, network threat intelligence (domains, IP ranges), and incident reports to create a holistic security approach.

3. Log Entry Structure and Common Signatures

3.1 Typical IAM Audit Log Fields

IAM audit logs capture detailed information for each event, including:

Field	Description
-------	-------------

timestamp	The UTC time when the event was recorded
event_type	The type of IAM event (e.g., CreateServiceAccount, UpdateScope)
User	Identity initiating the action
TargetResource	The resource affected, such as a service account or scope
ScopeID	Identifier for the scope, e.g., SCOPE-PROD-API-ADMIN
Method	The API or command used (e.g., gcloud, console action)
AdditionalDetails	Additional metadata, e.g., request ID, status

3.2 Signatures Indicative of Auto-Creation and Elevation

- Creation events with no prior approval logs
- Logs showing quick succession of create and permission change actions
- Entries referencing scope IDs associated with admin privileges, e.g., SCOPE-PROD-API-ADMIN
- Use of specific API patterns such as `gcloud iam service-accounts create`

3.3 Sample Log Entry

```
{
  "timestamp": "2024-07-15T12:34:56Z",
  "event_type": "CreateServiceAccount",
  "User": "automated-job-connector",
  "TargetResource": "projects/project-123/serviceAccounts/a",
  "ScopeID": "SCOPE-PROD-API-ADMIN",
  "Method": "gcloud iam service-accounts create",
  "AdditionalDetails": {
    "request_id": "req-7890123",
    "status": "SUCCESS"
  }
}
```

```
}
```

4. Detecting Service Account Auto-Creation Events

4.1 Principles of Detection

Automated creation of service accounts can be identified through specific log patterns, timing anomalies, and activity signatures.

Detection focuses on:

- New service account creation without prior administrative approval
- Unusual account naming conventions e.g., *auto-portal-sa*, *temp-svc*
- Rapid configuration changes post-creation
- Authorization logs indicating scripted API calls (e.g., via gcloud CLI)

4.2 Practical Detection Workflow

1. Query logs for `CreateServiceAccount` event types within the relevant time window.
2. Filter by scope IDs such as `SCOPE-PROD-API-ADMIN` or similar elevated scopes.
3. Cross-reference with IAM policy change logs to spot suspicious permission modifications immediately following account creation.
4. Automate alerting for sequences occurring outside scheduled maintenance windows or approval workflows.

4.3 Example Query (Pseudo-SQL)

```
SELECT * FROM iam_audit_logs
WHERE event_type = 'CreateServiceAccount'
      AND scope_id = 'SCOPE-PROD-API-ADMIN'
      AND timestamp BETWEEN '2024-07-01T00:00:00Z' AND '2024-07-
      AND user NOT IN (authorized_service_accounts)
      AND resource_name LIKE 'auto-%'
ORDER BY timestamp DESC;
```

4.4 Automation Tools and Scripts

Using cloud native tools such as `gcloud` CLI scripts, SIEM integrations, or custom monitoring scripts can streamline detection. Example snippet:

```
# Detect creation of service accounts with suspicious naming
gcloud logging read 'protoPayload.methodName="google.iam.adm
| jq '.protoPayload.request.resourceName' \
| grep 'auto-'
```

5. Scope Elevation and Privilege Escalation Detection

5.1 Indicators of Scope Elevation

Events indicating privilege escalation often involve changing scope permissions, increasing roles, or executing elevated API calls. Key signs include:

- Modifications to the scope `SCOPE-PROD-API-ADMIN` or similar high-privilege scopes
- Increase in admin-level IAM roles assigned to a service account or user
- Access logs showing elevated permission grants shortly after account creation
- Changes to IAM policy bindings with suspicious patterns, e.g., binding to `roles/owner`

5.2 Typical Log Patterns and Signatures

- Permission grant logs with method `SetIamPolicy` or `PatchServiceAccount`
- Use of API calls like `gcloud projects add-iam-policy-binding`
- Entries referencing scope IDs linked to administrative privileges

5.3 Incident Scenario Example

On 2024-07-20, an account *auto-portal-sa* was assigned the `roles/owner` on production project *project-123* shortly after creation. This

activity was flagged due to:

- Unusual timing within a 10-minute window
- No prior record of such elevation requests
- Associated network alerts from c2-host monitortools

5.4 Detection Strategy Summary

1. Monitor policy change logs for suspicious bindings
2. Alert on IAM modifications involving high-privilege roles
3. Cross-reference with known threat indicators such as ASN identifiers (e.g., ASN-64512)
4. Set thresholds for rapid succession of elevation events

6. Incident Examples and Analytical Scenarios

6.1 Scenario A: Automated Service Account Creation Followed by Scope Elevation

Summary: Over a 15-minute window, the logs showed the creation of a new service account *auto-portal-sa* followed by immediate role binding to `roles/owner`. The sequence involved:

- Log entries indicating creation via CLI command
- Subsequent 'SetIamPolicy' calls to assign elevated permissions

Detection Steps:

1. Query for recent `CreateServiceAccount` events with scope ID *SCOPE-PROD-API-ADMIN*
2. Check for policy modifications within 10 minutes of account creation
3. Verify whether the user initiating the change was authorized

6.2 Scenario B: Known Malicious Signatures (BEACON-12xx)

Event logs revealed network communication attempts matching signatures like *BEACON-1245*, and C2-DNS patterns such as *c2-host-01.example*. The EDR artifacts included:

- SHA256 hash: abc123def456...
- Command line pattern: mshta.exe | encoded PowerShell commands

Actions:

1. Correlate log signatures with network IOC (Indicators of Compromise)
2. Isolate affected hosts and terminate malicious processes
3. Review IAM logs for unauthorized account or scope modifications associated with the threat activity

6.3 Summary of Findings and Lessons Learned

Maintaining vigilant log analysis, cross-referencing with threat intelligence, and automating detection reduces dwell time and minimizes impact from automated attacks.

7. Detection Signatures and False Positives

7.1 Known Signatures

Signature	Description	Example
BEACON-1245	Malicious beacon traffic signature	Network pattern matching
C2-DNS-30xx	Command-and-control DNS patterns	c2-host-01.example
GCloud Create Service Account	Suspicious automation	Logs with method gcloud iam service-accounts create

7.2 Common False Positives and Mitigation

- Automated legitimate account creation during onboarding (filter by known service accounts)
- Authorized security scans or maintenance scripts (correlate with change logs)
- False alarms from shared IPs or ASN ranges (requires

contextual validation)

7.3 Best Practices for Filtering

- Implement whitelist policies for known automation tools
- Set alert severity thresholds based on activity patterns
- Leverage anomaly detection on account behaviors and scope modifications

8. Response Strategies and Mitigation

8.1 Immediate Containment

- Isolate affected service accounts and disable suspicious IAM bindings
- Block malicious network communications identified via C2 signatures
- Terminate any active malicious processes on compromised hosts

8.2 Investigation and Forensics

- Collect logs from IAM, network, and endpoint sources
- Identify the scope of compromise
- Determine if additional accounts or resources were affected

8.3 Recovery and Hardening

- Revoke unnecessary elevated privileges
- Implement stricter IAM policies and approval workflows
- Set up continuous monitoring and alerting for similar signatures

8.4 API Throttling Playbooks

In high-activity scenarios, throttle API calls to prevent abuse. Example: configure quota limits on IAM APIs to slow rapid auto-creation or modification attempts.

8.5 Partner OAuth and External Access Review

Regularly review partner OAuth consents and external access permissions to exclude external accounts from privilege escalation

vectors.